

گزارش آزمون نفوذپذیری

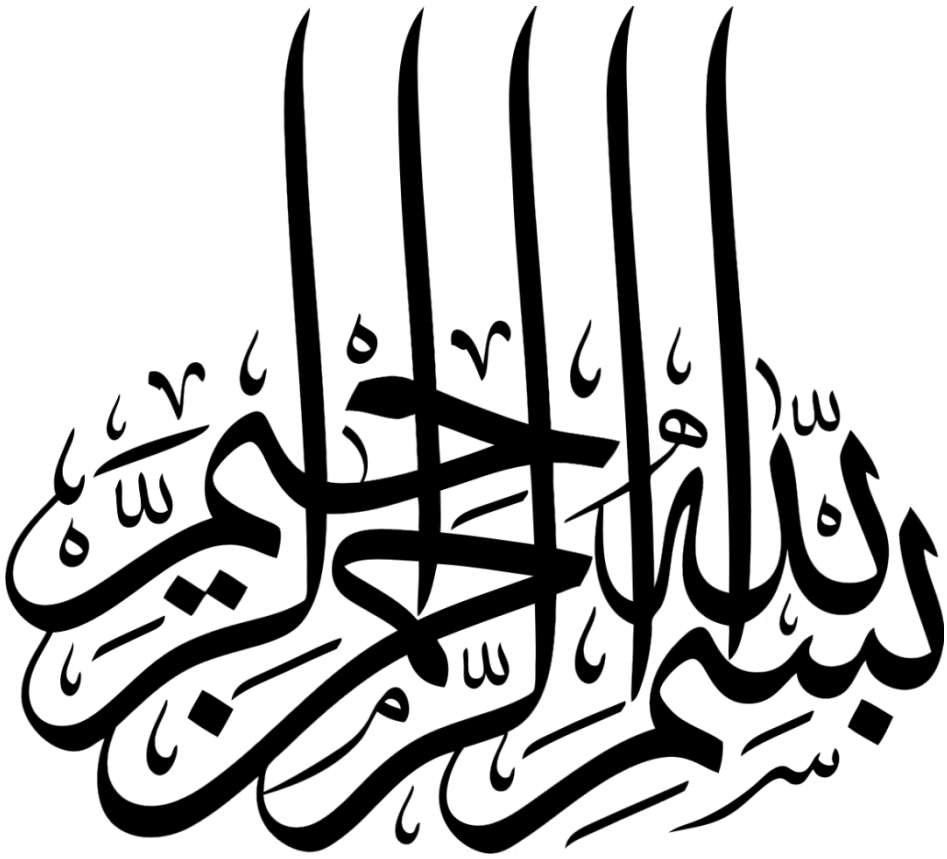
سامانه fanava.com

شرکت فناوران طلوع شبکه

محرمانه

۱۴۰۴/۰۱/۳۰

Toluo_fanava_com_PentestReport


بسم الله الرحمن الرحيم

فهرست مطالب

عنوان | صفحه

فصل ۱- مقدمه و خلاصه نتایج ۵

۱-۱- دسته کلاس‌های آزمون نفوذ ۶

۱-۲- محاسبه شدت آسیب‌پذیری‌ها ۶

۱-۳- اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون ۷

۱-۳-۱- شناسایی وب‌سرور ۷

۱-۳-۲- بررسی سرویس‌های امنیتی ۹

۱-۴- خلاصه مدیریتی ۱۰

فصل ۲- تشریح آسیب‌پذیری‌های کشف شده ۱۲

۲-۱- آسیب‌پذیری Vulnerability of Plugins – No Update ۱۲

۲-۲- آسیب‌پذیری Denial Of Service ۱۴

۲-۳- آسیب‌پذیری Account Enumeration and Guessable User Account ۱۶

۲-۴- آسیب‌پذیری ClickJacking ۱۹

۲-۵- آسیب‌پذیری Directory Browsing Enable ۲۲

۲-۶- آسیب‌پذیری HTTP Splitting Smuggling ۲۳

۲-۷- فعال بودن XMLRPC ۲۵

۲-۸- فعال بودن WP-Cron ۲۷

۲-۹- آسیب‌پذیری Information Leakage ۲۹

۲-۱۰- آسیب‌پذیری Weak Lock Out Mechanism ۳۱

۲-۱۱- آسیب‌پذیری Rate Limit ۳۲

۲-۱۲- آسیب‌پذیری Nginx Version Disclosure ۳۴

۲-۱۳- آسیب‌پذیری Information Disclosure ۳۵

فصل ۱– مقدمه و خلاصه نتایج

در دنیای امروز، که هر شرکت یا سازمانی دارایی‌های مختلف حوزه فناوری اطلاعات را در خود جای داده است، امنیت این دارایی‌ها نیز درجایگاه مهمی‌قرار می‌گیرد.

در صورتی که هیچ گونه محافظتی از این دارایی‌ها به عمل نیاید، امکان آسیب به آن از طرق مختلف متصور خواهد بود. البته وجود ابزارهای امنیتی مانند فایروال، آنتی ویروس، سیستم‌های تشخیص نفوذ و غیره، در این زمینه بسیار مفید هستند ولی وجود این ابزارها به تنهایی منجر به برقراری امنیت نمی‌شود. چرا که در خیلی از موارد مشاهده شده که حتی با وجود ابزارهای امنیتی مذکور، باز هم دسترسی به دارایی‌های سازمان توسط نفوذگران انجام شده است.

یکی از انواع خدماتی که در زمینه امنیت به شما در شناسایی و رفع مشکلات امنیتی کمک شایانی می‌نماید، تست نفوذ و ارزیابی امنیتی می‌باشد.

در فرآیند تست نفوذ سعی می‌شود تا آسیب‌پذیری‌های موجود در دارایی‌های شرکت یا سازمان، شناسایی شده و با ارائه راهکار رفع آن، آسیب‌پذیری موجود برطرف گردد.

مستند پیش‌رو، گزارش آزمون نفوذپذیری سامانه fanava.com است که توسط شرکت "فناوران طلوع شبکه" تدوین شده است.

۱-۱- دسته کلاس‌های آزمون نفوذ

متخصصان ارزیابی امنیتی و آزمون نفوذ شرکت «فناوران طلوع شبکه» با استفاده از متدولوژی‌ها و استانداردهای مختلف در حوزه برنامه‌های کاربردی تحت وب، مانند Web Security Testing Guide مربوط به OWASP در ترکیب با تجربه عملی خود در آزمون نفوذپذیری برنامه‌های کاربردی تحت وب در حوزه‌های مختلف اقدام به آزمون نفوذپذیری این سامانه‌ها می‌نمایند.

دسته کلاس‌های مورد آزمون برای برنامه‌های کاربردی تحت وب به صورت زیر طراحی شده است:

۱. جمع‌آوری اطلاعات
۲. آزمون پیکربندی و مدیریت استقرار
۳. آزمون مدیریت هویت
۴. آزمون تصدیق اصالت
۵. آزمون مجازشماری
۶. آزمون مدیریت نشست
۷. آزمون اعتبارسنجی ورودی‌ها
۸. آزمون مدیریت خطاها
۹. آزمون رمزنگاری
۱۰. آزمون منطق کسب‌وکار
۱۱. آزمون سمت کاربر

۱-۲- محاسبه شدت آسیب‌پذیری‌ها

شدت یک آسیب‌پذیری با الهام از سیستم نمره‌دهی CVSS v3.1 محاسبه خواهد شد، که راهنمای آن در جدول زیر آورده شده است.

Severity	Score Range
Critical	**9.0 – 10.0**
High	**7.0 – 8.9**
Medium	**4.0 – 6.9**
Low	**0.1 – 3.9**

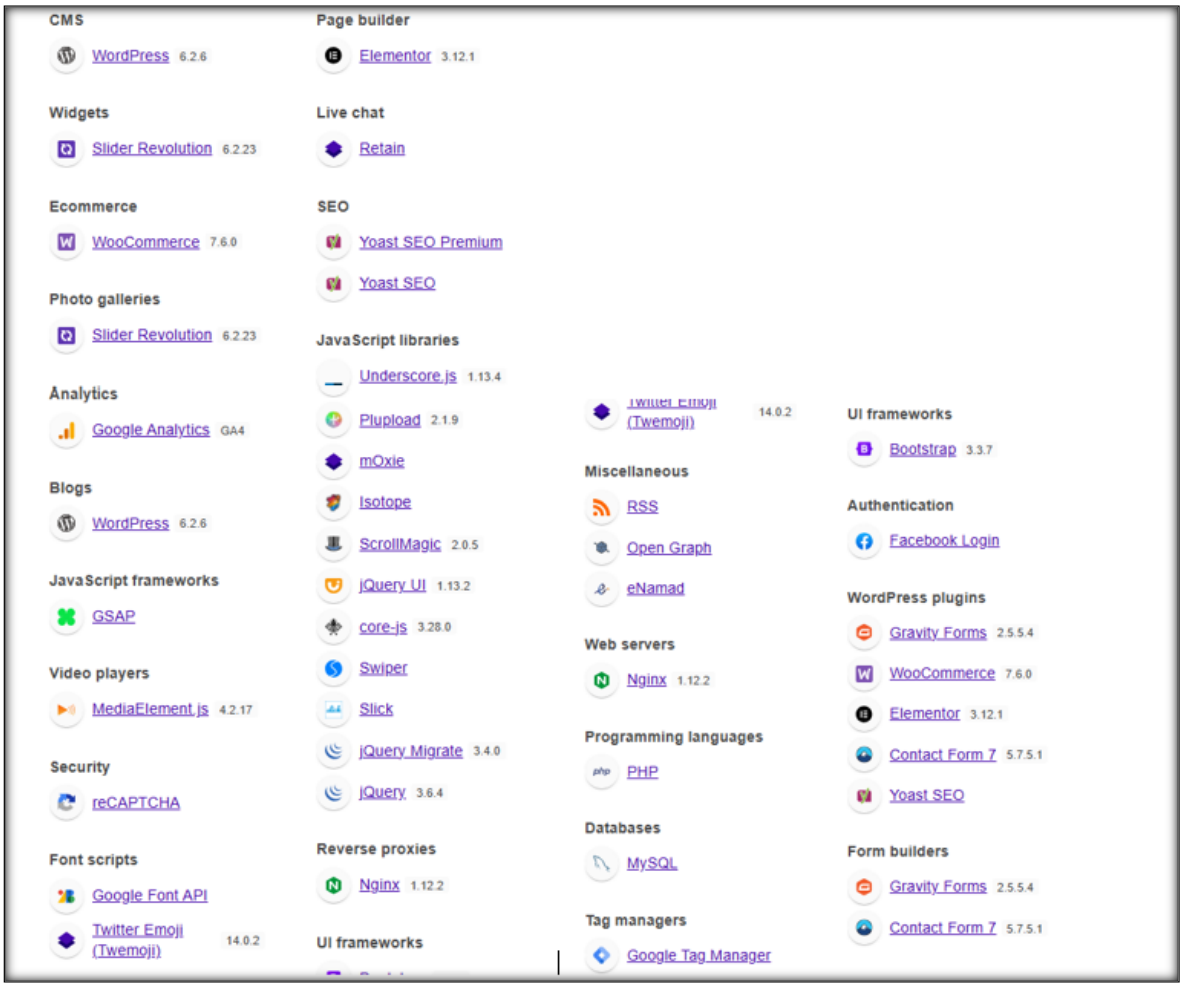
۳-۱- اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون

۱-۳-۱-شناسایی وب‌سرور

در صورت امکان، شناسایی وب‌سرور جزو وظایف حیاتی برای نفوذگر است. دانستن نسخه و نوع وب‌سرور، به نفوذگران اجازه می‌دهد تا آسیب‌پذیری‌های شناخته‌شده و روش‌های بهره‌برداری از آن‌ها را مشخص و در طول آزمون از آنها استفاده کنند. بنابراین، هدف این نوع آزمون، یافتن نسخه و نوع وب‌سرور برای تعیین آسیب‌پذیری‌های شناخته‌شده و روش‌های مناسب بهره‌برداری از آنها در طول ارزیابی است.

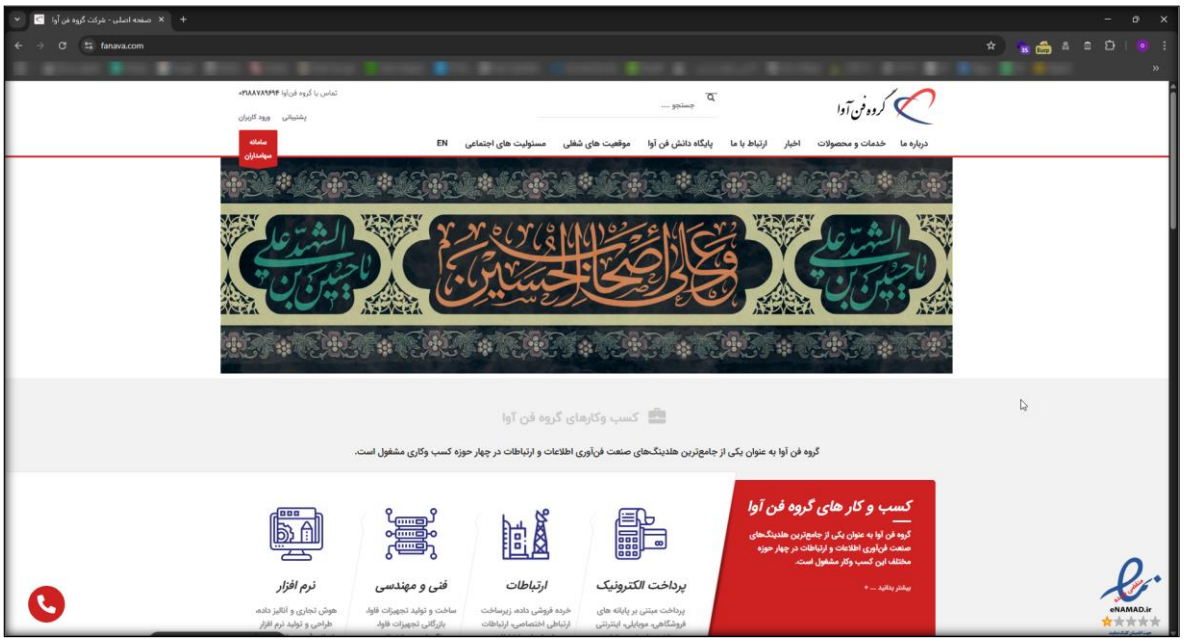
شناسایی فریم‌ورک‌ها و تکنولوژی‌های فعال روی سامانه

با بررسی هدرها، کوکی‌ها و اسامی فیلدهای مختلف سامانه و با استفاده از ابزارهایی از قبیل Wappalyzer، اطلاعات زیر درباره تکنولوژی‌های استفاده‌شده در سامانه هدف استخراج شد:



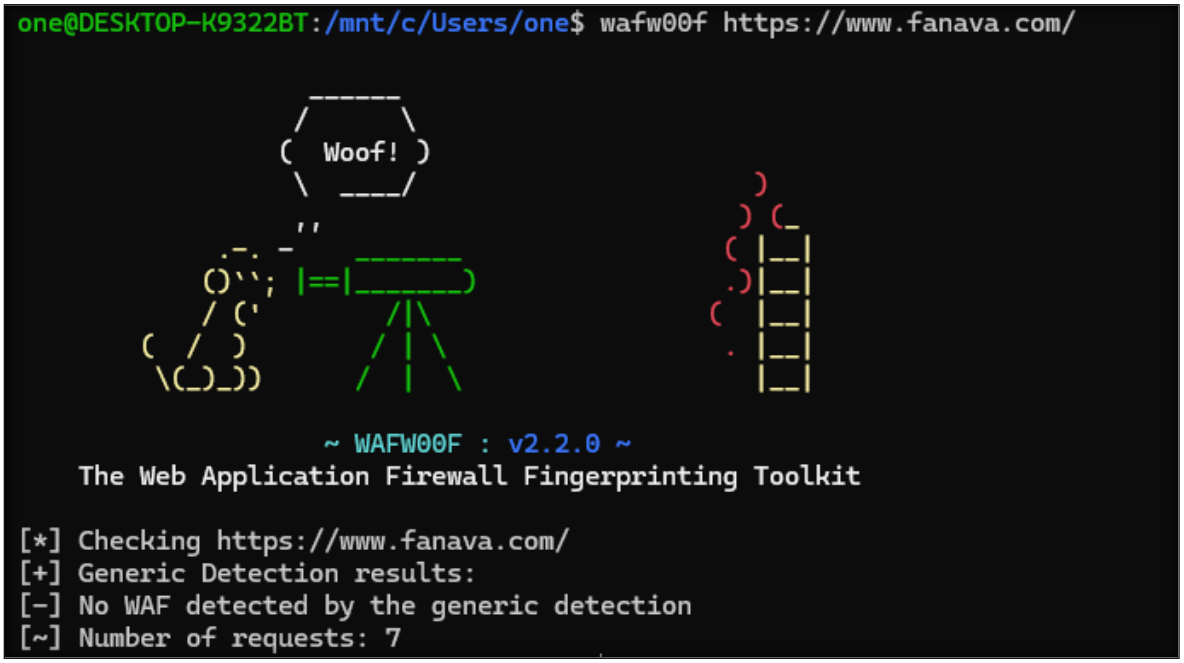
سامانه هدف با آدرس https://www.fanava.com در حال سرویس‌دهی است که صفحه نخست آن در تصویر زیر نمایش داده شده است:

نکته: سایت دارای وضعیت پایداری نمی‌باشد و با توجه به افزایش بازدید کننده در سطح بسیار پایین حدود ۲۰ نفر سایت تاخیر در پاسخ داشته و در بعضی موارد امکان سرویس دهی ندارد.



۲-۱-۳-بررسی سرویس‌های امنیتی

با توجه به بررسی‌های انجام شده، مکانیزم امنیتی خاصی به منظور جلوگیری از حملات و بررسی درخواست‌های مخرب، در سامانه مشاهده نگردید. تصویر زیر نمایانگر این موضوع می‌باشد:





۴-۱- خلاصه مدیریتی

بررسی‌های انجام شده بر روی سامانه نمایانگر این موضوع است که وضعیت کلی سامانه fanava.com در وضعیت ریسک متوسط قرار دارد. البته موارد با سطح ریسک بالا شناسایی شده مربوط به عدم بروزرسانی پلاگین‌های وردپرس و ضعف منابع سامانه در برابر حمله Dos می‌باشد و با رفع مشکلات موجود در این بخش، اغلب موارد مرتفع می‌گردد. همچنین لازم به ذکر است که آسیب‌پذیری‌های سطح ریسک متوسط و کم نباید نادیده گرفته شده و با توجه به تجمیع برخی از آن‌ها، امکان سوء استفاده از این سطح آسیب‌پذیری‌ها در صورت عدم رفع، وجود خواهد داشت.



در جدول زیر، تعداد آسیب‌پذیری‌هایی که روی سامانه هدف شناسایی شدند، به تفکیک درجه ریسک هر کدام، آورده شده‌اند:

ردیف	سامانه هدف	تعداد آسیب‌پذیری‌ها			
		آسیب‌پذیری‌های با ریسک بحرانی	آسیب‌پذیری‌های با ریسک بالا	آسیب‌پذیری‌های با ریسک متوسط	آسیب‌پذیری‌های با ریسک کم
۱	https://www.fanava.com	۰	۲	۹	۲

به‌علاوه، عناوین آسیب‌پذیری‌هایی که بر روی سامانه هدف شناسایی شدند، به تفکیک درجه ریسک آن‌ها به‌صورت زیر است.

لازم به ذکر است که موارد مشخص شده در ادامه گزارش، به صورت نمونه بوده و آسیب‌پذیری‌ها می‌بایست در کل سامانه مرتفع گردند.

نام	درجه اهمیت
Vulnerability of Plugins – No Update	زیاد
Denial Of Service	زیاد
Account Enumeration and Guessable User Account	متوسط
ClickJacking	متوسط
Directory Browsing Enable	متوسط
HTTP Splitting Smuggling	متوسط
XMLRPC	متوسط
WP-Cron	متوسط
Information Leakage	متوسط
Weak Lock Out Mechanism	متوسط
Rate Limit	متوسط
Nginx Version Disclosure	کم
Information Disclosure	کم

فصل ۲- تشریح آسیب‌پذیری‌های کشف شده

در ادامه، برای آسیب‌پذیری‌های کشف‌شده در سامانه، توضیحات تکمیلی مرتبط ارائه شده است:

۲-۱- آسیب‌پذیری Vulnerability of Plugins – No Update

عدم بروز رسانی قالب و افزونه‌های مورد استفاده در سیستم مدیریت محتوای سامانه منجر افزایش احتمال نفوذ می‌گردد.

پس از بررسی‌های انجام شده بر روی سامانه هدف مشخص گردید این سامانه از نسخه قدیمی سیستم مدیریت محتوای Wordpress استفاده می‌کند و نیاز به بروز رسانی دارد.

```
[+] WordPress version 6.2.6 identified (Outdated, released on 2024-06-24).
 | Found By: Rss Generator (Passive Detection)
 |  - https://www.fanava.com/feed/, <generator>https://wordpress.org/?v=6.2.6</generator>
 |  - https://www.fanava.com/comments/feed/, <generator>https://wordpress.org/?v=6.2.6</generator>
```

```
[WP VERSION]
WordPress Version: WordPress 6.2.6
Try to Passive detect...
WordPress Version: 6.2.6
```

همچنین پس از شناسایی افزونه‌های نصب شده، لیست مواردی که نیاز به بروزرسانی دارند عبارتند از:

Woocommerce از نسخه ۷.۶.۰ استفاده می‌کند و نیاز به بروزرسانی دارد.

Contact Form 7 از نسخه ۵.۷.۵.۱ استفاده می‌کند و نیاز به بروزرسانی دارد.

Revolation Slider از نسخه ۶.۲.۲۳ استفاده می‌کند و نیاز به بروزرسانی دارد.

Elementor از نسخه ۳.۱۲.۱ استفاده می‌کند و نیاز به بروز رسانی دارد.

Elementor Pro از نسخه ۱۳.۱۲.۲ استفاده می‌کند و نیاز به بروزرسانی دارد.

```
[WP Plugin Version]
[FOUND] woocommerce : 7.6.0
[FOUND] contact-form-7 : 5.7.5.1
[FOUND] revslider : 6.2.23
[FOUND] kl-woocommerce.css?ver=4.17.1 : 4.17.1
[FOUND] elementor : 3.12.1
[FOUND] elementor-pro : 3.12.2
[FOUND] fontiran : 6.2.6
```

راهکار پیشنهادی:

به منظور رفع آسیب‌پذیری‌های مطرح شده پیشنهاد می‌گردد تا موارد زیر مد نظر قرار گیرد:

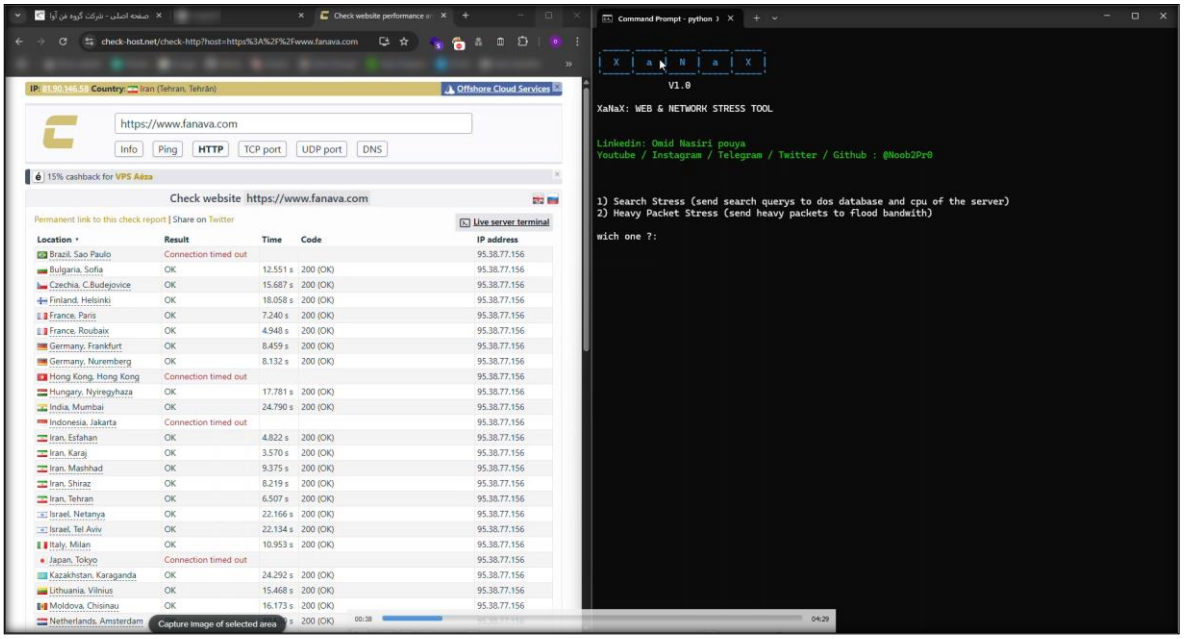
- استفاده از آخرین نسخه انتشار یافته وردپرس و افزونه‌های موجود
- استفاده از بروزرسانی خودکار
- استفاده از نسخه original قالب و افزونه‌ها

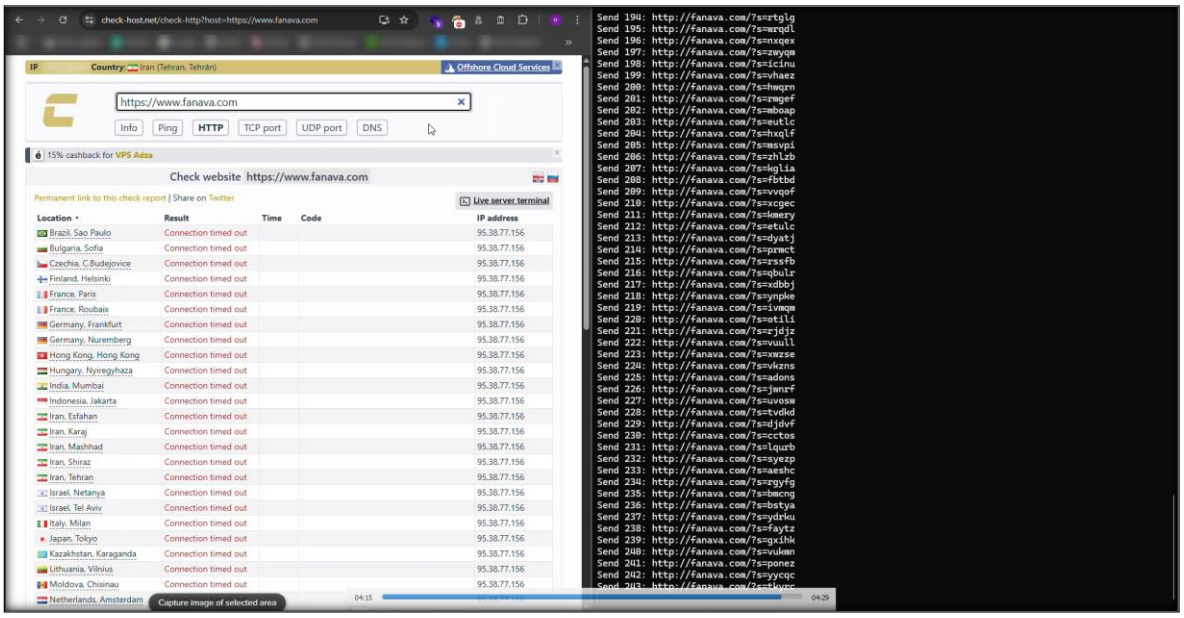
۲-۲- آسیب‌پذیری Denial Of Service

در تصور عموم مردم این طور جا افتاده است که حملات DOS تنها به ارسال بسته‌های زیاد و سنگین از یک مبدا به یک مقصد به جهت جلوگیری و اختلال در سرویس دهی اتفاق می‌افتد، اما در حقیقت این حمله یک بستر بزرگتر از آن چیزی که فکر می‌کنیم دارد، آنقدر بزرگ که شکل‌های بسیار مختلفی برای اختلال و عدم سرویس دهی سرویس دهنده وجود دارد، بعضی مواقع برنامه نویسان دچار اشتباهاتی می‌شوند که نفوذگر تنها با ارسال ۱ درخواست منجر به اختلال و یا جلوگیری از سرویس دهی سرویس دهنده می‌شود.

طی بررسی‌های صورت گرفته مشخص گردید به علت استفاده از فضای وب اشتراکی (هاست) منابع این سامانه بشدت محدود بوده به طوری که با افزایش بازدید کننده تا حدود ۲۰ تا همزمان باعث می‌شود سایت بشدت کند و در بعضی موارد بصورت کامل از دسترس خارج شود.

در راستای بررسی پایداری سایت توسط ابزار استرس سایت این سامانه به مدت چند دقیقه مورد استرس قرار گرفته و مشخص گردید که دارای آسیب‌پذیری نسبت به حمله Denial of Service می‌باشد.





راهکار پیشنهادی:

به منظور رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

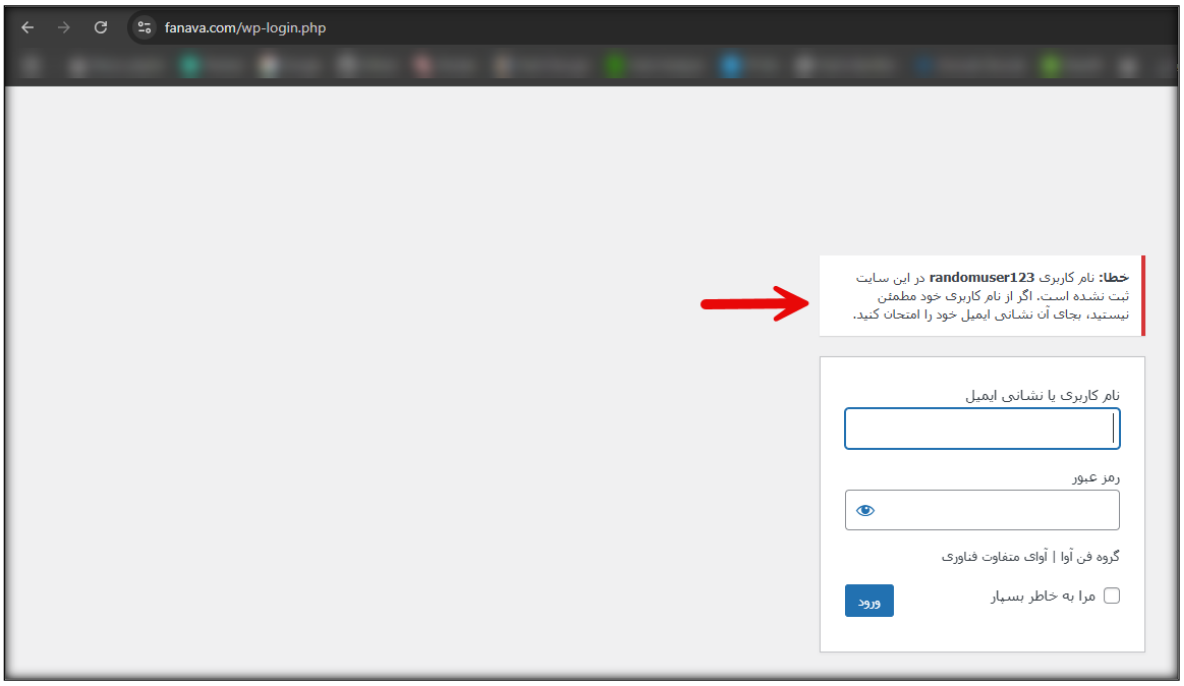
- جلوگیری از ارسال مکرر درخواست‌های تکراری از یک مبدا
- بررسی مجدد مقدارهای سمت کاربر در سمت رور
- در صورت امکان مقادیر در سمت کاربر نباشند.

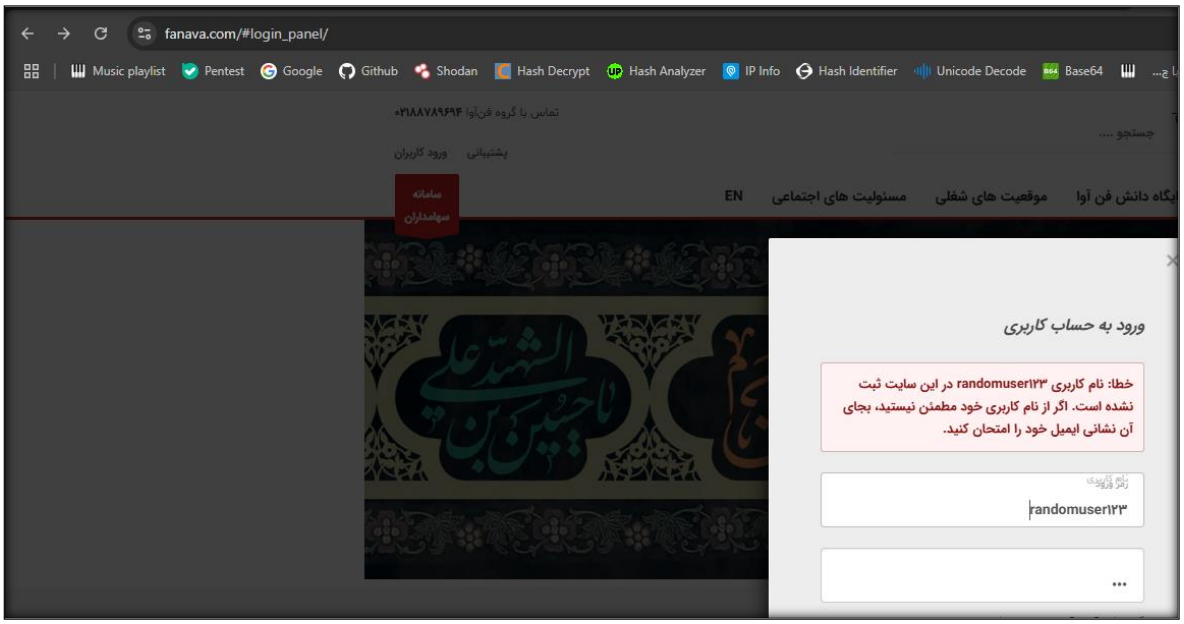
۳-۲- آسیب‌پذیری Account Enumeration and Guessable User Account

در این آزمون مشخص می‌شود که آیا امکان جمع‌آوری نام‌های کاربری (در اینجا ایمیل‌های کاربران) موجود در سامانه در طی فرآیند احرازهویت وجود دارد یا خیر. نتایج مربوط به این بخش در انجام حملات Brute Force مورد استفاده قرار می‌گیرد؛ به‌گونه‌ای که با در دست داشتن نام‌های کاربری صحیح، نفوذگر می‌تواند اقدام به پیدا کردن کلمه عبور متناظر با آن نماید.

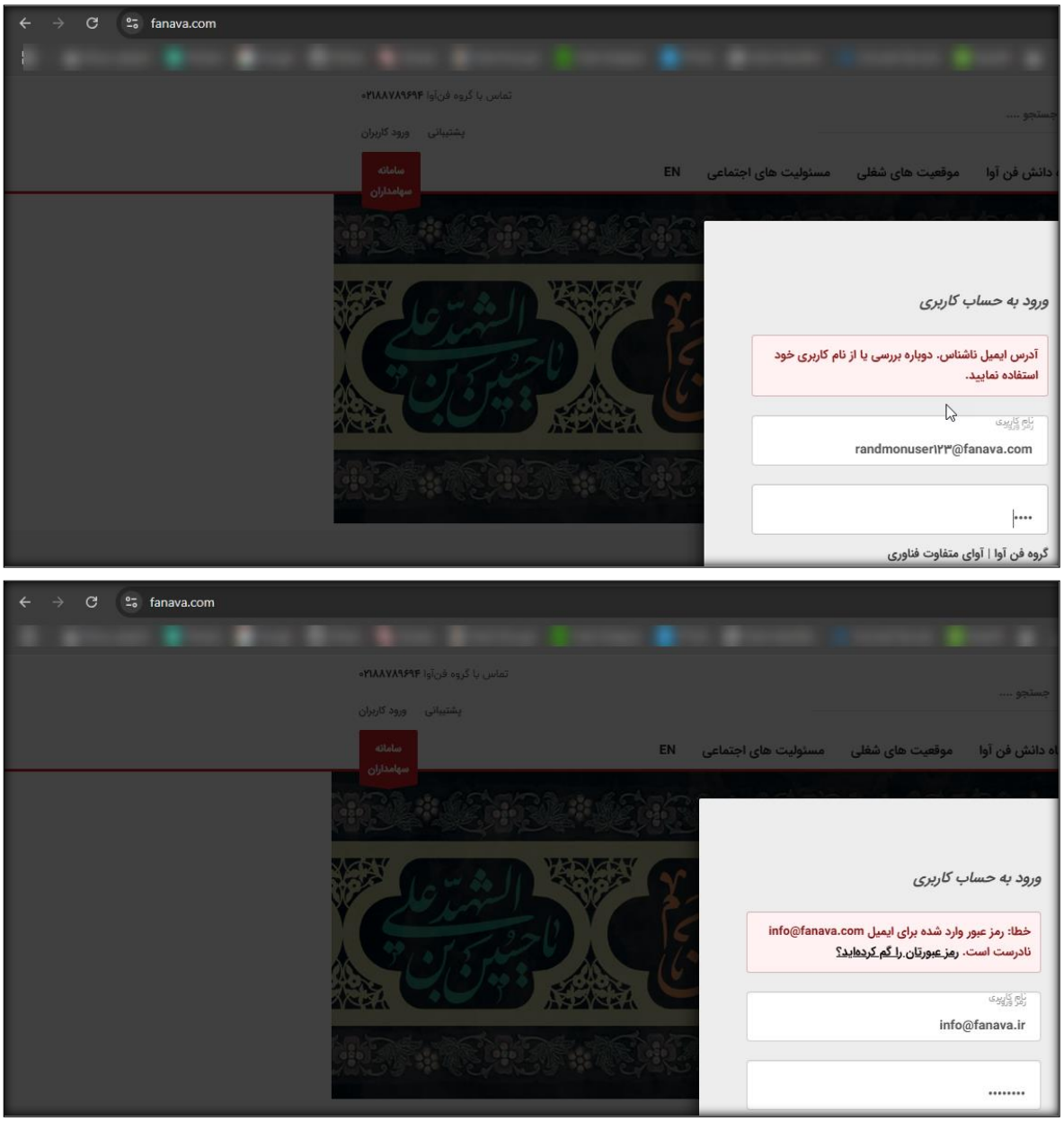
اغلب وب‌اپلیکشن‌ها بر اثر خطا در طراحی و یا به‌صورت هدفمند، وجود یا عدم وجود یک نام‌کاربری در پایگاه‌داده را فاش می‌کنند. به عنوان نمونه، زمانی که نام‌کاربری اشتباه باشد، پیغام خطای متفاوتی نسبت به زمانی که نام کاربری صحیح است ولی رمزعبور اشتباه است، به کاربر نشان داده می‌شود. این موارد جهت جمع‌آوری اطلاعات، بررسی وجود یک کاربر خاص روی سامانه و در نهایت اقدام به انجام Brute Force و بدست آوردن کلمه عبور، مفید است.

پس از بررسی‌های صورت گرفته مشخص گردید سامانه هدف دارای آسیب‌پذیری User Enumebration می‌باشد.




fanava.com/#login_panel/
Music playlist
Pentest
Google
Github
Shodan
Hash Decrypt
Hash Analyzer
IP Info
Hash Identifier
Unicode Decode
Base64
EN
مسئولیت های اجتماعی
موقعیت های شغلی
ورود به حساب کاربری
خطا: نام کاربری randomuser۱۲۳ در این سایت ثبت نشده است. اگر از نام کاربری خود مطمئن نیستید، بجای آن نشانی ایمیل خود را امتحان کنید.
randomuser۱۲۳


[User Enumeration]
[ID]
[SITEMAP]
[FOUND] adminfanava
[WP-JSON]
[RSS/feed]
[FOUND] مدیر
[OtherMethods]
[FOUND] https://www.fanava.com/author/adminfanava/



راهکار پیشنهادی

توصیه می‌شود در صورت امکان، با مدیریت صحیح خطاهای نمایشی، از نمایش خطاهای مربوط به عدم وجود کاربر که منجر به توانایی نفوذگر در شناسایی حساب‌های کاربری می‌شود، اجتناب گردد. همچنین در صورت ورود نام کاربری صحیح یا نادرست، پیام خطای یکسانی به کاربر نمایش داده شود.

۴-۲- آسیب‌پذیری ClickJacking

Clickjacking، زیرمجموعه‌ای از حملات اصلاح UI بوده و یک تکنیک مخرب است که به موجب آن یک کاربر وب فریب خورده تا با چیزی غیر از آنچه که کاربر معتقد است با آن تعامل دارد (در اکثر موارد با کلیک کردن) تعامل داشته باشد. این نوع حمله، چه به تنهایی و چه همراه با سایر حملات، به طور بالقوه می‌تواند دستورات غیرمجاز ارسال کند یا اطلاعات محرمانه را در حالی که قربانی در حال تعامل با صفحات وب به ظاهر بی ضرر است، فاش کند.

حمله Clickjacking از ویژگی‌های به ظاهر بی‌ضرر HTML و جاوا اسکریپت استفاده می‌کند تا قربانی را مجبور به انجام اقدامات نامطلوب کند، مانند کلیک کردن روی یک دکمه نامرئی که عملیات ناخواسته را انجام می‌دهد. این یک مشکل امنیتی سمت کلاینت است که بر انواع مرورگرها و پلتفرم‌ها تأثیر می‌گذارد.

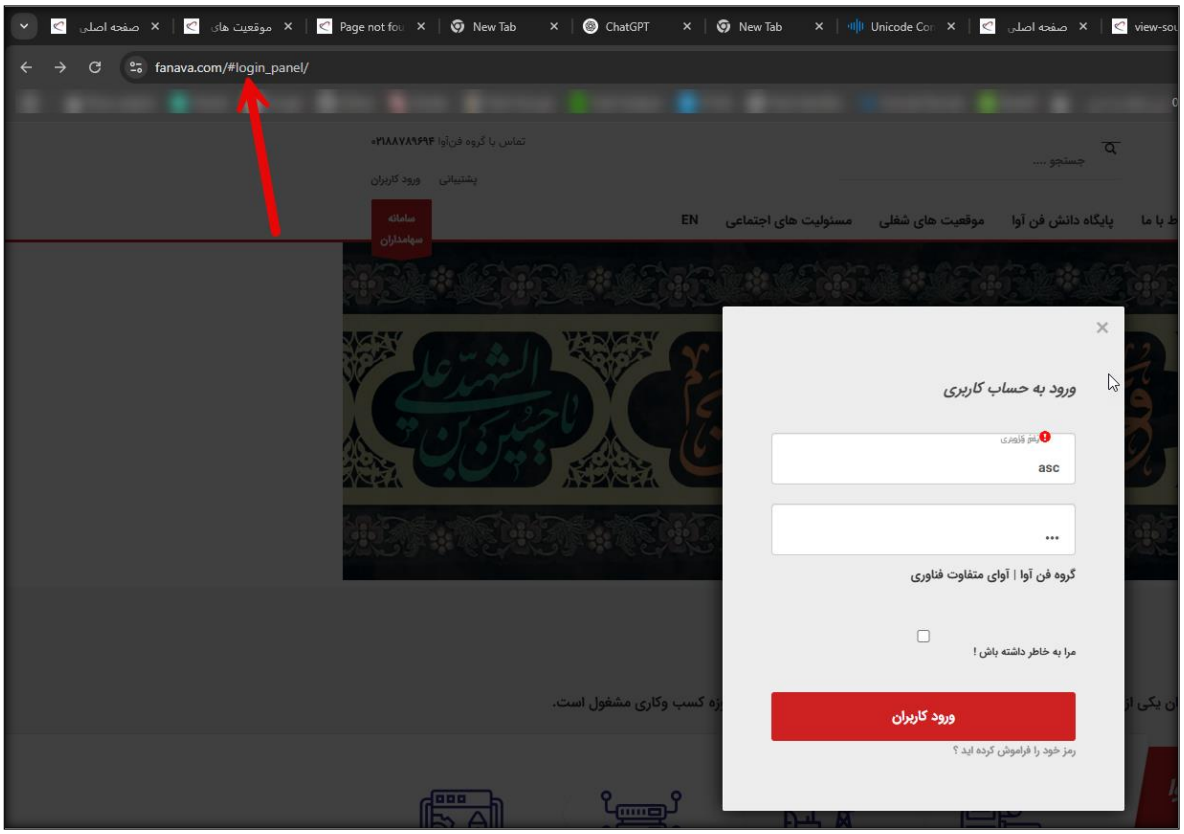
برای انجام این حمله، یک مهاجم یک صفحه وب به ظاهر بی ضرر ایجاد می‌کند که برنامه مورد نظر را با استفاده از یک فریم درون خطی (مخفی شده با کد CSS) بارگذاری می‌کند. هنگامی که این کار انجام شد، مهاجم ممکن است قربانی را به تعامل با صفحه وب با ابزارهای دیگر (مثلاً از طریق مهندسی اجتماعی) وادار کند. مانند سایر حملات، یک پیش نیاز رایج این است که قربانی در برابر وب سایت هدف مهاجم احراز هویت شود.

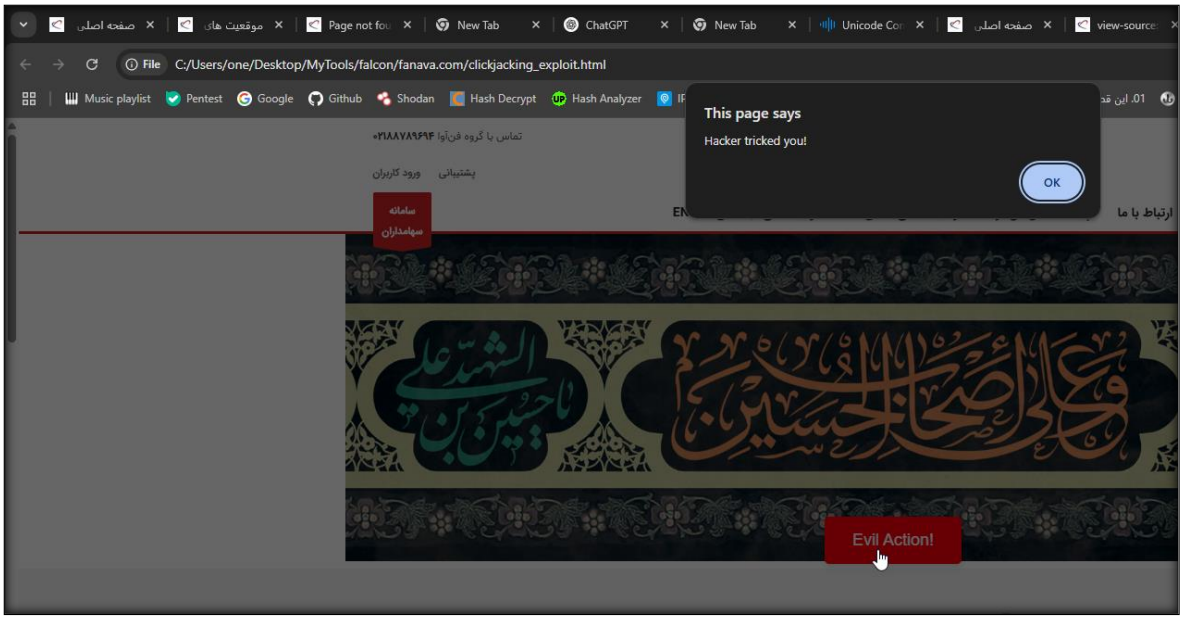
همانطور که در تصویر زیر قابل مشاهده می‌باشد هدر X-FRAME-OPTIONS در پاسخ درخواست مشاهده نمی‌شود که همین موضوع منجر به آسیب‌پذیر بودن سامانه به ClickJacking می‌شود:

```
[SECURITY HEADERS]
[FAILD] X-Frame-Options
[FAILD] X-XSS-Protection
[FAILD] Cache-Control
[FAILD] X-Content-Type-Options
[FAILD] Strict-Transport-Security
[FAILD] Content-Security-Policy
```

تصویر زیر نیز مربوط به بارگذاری سایت در یک Iframe را نمایش می‌دهد:

نکته: صفحه ورود کاربر/مدیر در همان صفحه اول می‌باشد که با #login_panel قابل مشاهده می‌باشد.


fanava.com/#login_panel/
ورود به حساب کاربری
asc
گروه فن آوا | آوای متفاوت فناوری
مرا به خاطر داشته باش !
ورود کاربران
رمز خود را فراموش کرده اید ؟


File C:/Users/one/Desktop/MyTools/falcon/fanava.com/clickjacking_exploit.html
This page says
Hacker tricked you!
OK
Evil Action!

راهکار پیشنهادی

برای جلوگیری از حملاتClickjacking ، می‌توان از روش‌های زیر استفاده کرد:

استفاده از هدرهای HTTP امنیتی یکی از موثرترین و پرکاربردترین روش‌ها برای جلوگیری از Clickjacking است که شامل موارد زیر می‌باشد:

X-Frame-Options: این هدر مشخص می‌کند که آیا مرورگر اجازه دارد محتوای صفحه را درون iFrame نمایش دهد یا خیر. سه گزینه معمول برای این هدر وجود دارد:

- **DENY**: اجازه نمی‌دهد که صفحه درون iFrame قرار گیرد.
- **SAMEORIGIN**: تنها در صورتی اجازه می‌دهد صفحه درون iFrame نمایش داده شود که از همان دامنه باشد.
- **ALLOW-FROM URI**: تنها اجازه نمایش درون iFrame با دامنه یا URL مشخص شده را می‌دهد (البته این گزینه کمتر استفاده می‌شود، زیرا برخی مرورگرها آن را پشتیبانی نمی‌کنند).

Content Security Policy (CSP): این هدر پیشرفته‌تر از X-Frame-Options است و با تنظیم آن می‌توانید مشخص کنید که منابع صفحه از کدام دامنه‌ها بارگذاری شوند. برای جلوگیری ازClickjacking ، می‌توانید از دستور frame-ancestors استفاده کنید:

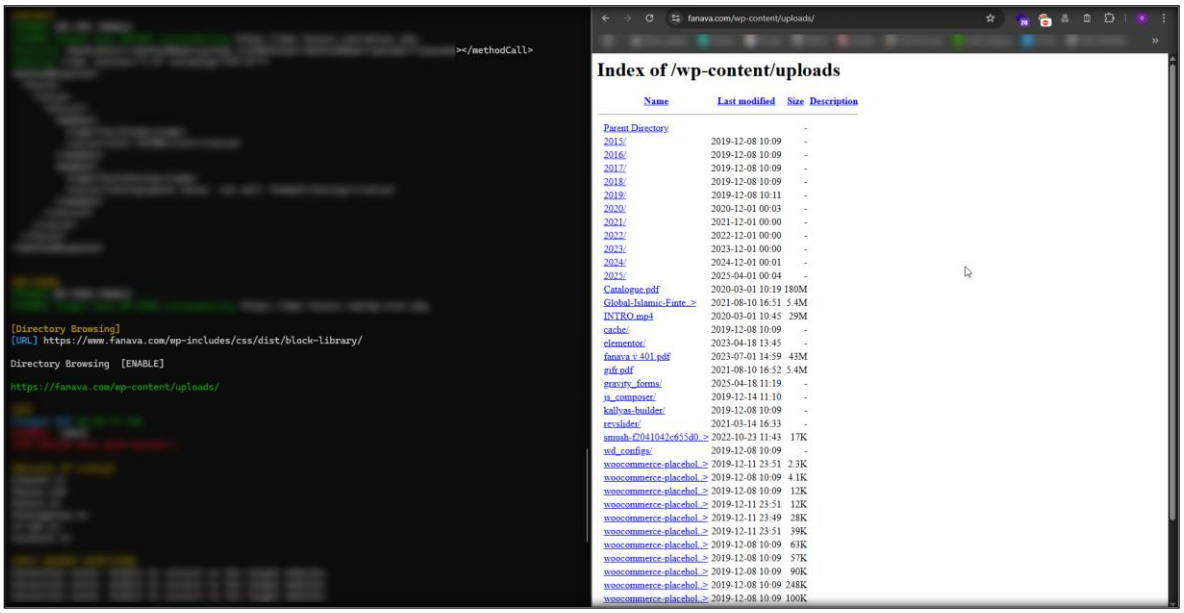
```
Content-Security-Policy: frame-ancestors 'self';
```

۵-۲- آسیب‌پذیری Directory Browsing Enable

یکی از مواردی که مربوط به تنظیمات سرور بوده و باید غیرفعال باشد، قابلیت Directory Listing می‌باشد.

در صورت فعال بودن این قابلیت، امکان دسترسی به لیست و محتویات فایل‌ها و پوشه‌های موجود بر روی سرور وجود دارد که این موضوع در شرایطی که فایل‌های محرمانه بر روی وب سرور وجود داشته باشد، می‌تواند موجب دسترسی افراد غیر مجاز به آنها و درنتیجه افشای اطلاعات آن‌ها گردد.

طی بررسی‌های صورت گرفته مشخص گردید ویژگی Directory Browsing در این سامانه فعال می‌باشد که می‌توان تمام فایل‌های بارگزاری شده در سایت را مشاهده کرد، در بررسی‌های عمیق تر از این آسیب‌پذیری فایل‌های نسخه پشتیبان و یا موارد مهم از جمله اطلاعات کارکنان و کاربران مشاهده نگردید اما با وجود این آسیب‌پذیری نشت اطلاعات در آینده متصور است.



راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری می‌بایست قابلیت Directory Browsing در وب سرور غیرفعال گردیده و همچنین امکان دسترسی به صفحاتی که دارای اطلاعات حساس هستند، تنها به حساب‌های کاربری مشخص، محدود گردد.

۶-۲- آسیب‌پذیری HTTP Splitting Smuggling

HTTP Smuggling یک نوع آسیب‌پذیری در پروتکل HTTP است که به مهاجم امکان می‌دهد درخواست‌های HTTP را به گونه‌ای دستکاری کند که سرور اصلی و سرور پراکسی (یا لود بالانسر) به اشتباه درخواست‌های متفاوتی را پردازش کنند. این آسیب‌پذیری زمانی رخ می‌دهد که یک سیستم از چندین سرور و پروکسی برای پردازش درخواست‌های HTTP استفاده می‌کند و بین سرورها، هم‌ترازی در تفسیر درخواست‌ها وجود ندارد.

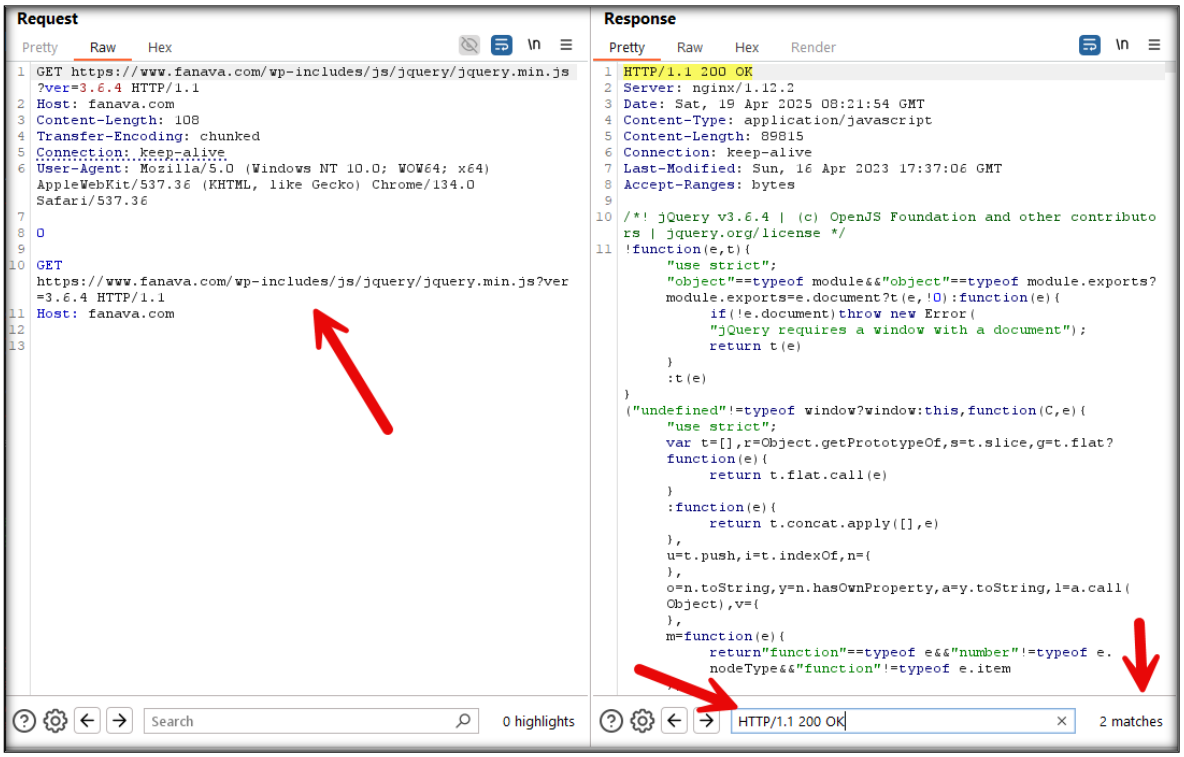
اگر سرور پراکسی و سرور اصلی به صورت متفاوتی ساختار درخواست را تفسیر کنند، مهاجم می‌تواند با دستکاری خاصی، دو درخواست مجزا را طوری ترکیب کند که یکی از آن‌ها برای سرور اصلی و دیگری برای سرور پراکسی پردازش شود. این عدم هم‌ترازی می‌تواند به مهاجم اجازه دهد تا:

- **از محدودیت‌های امنیتی عبور کند:** مهاجم می‌تواند دسترسی به منابعی داشته باشد که معمولاً محدود شده‌اند.
- **اجرای درخواست‌های غیرمجاز:** می‌تواند درخواست‌های مخربی ارسال کند که سرور آن‌ها را به عنوان درخواست‌های معتبر پردازش می‌کند.
- **اجرای حملات دیگر:** مانند تزریق اسکریپت، سرقت اطلاعات یا دور زدن محدودیت‌های احراز هویت.

پس از تست‌های انجام شده بر روی سامانه هدف مشخص گردید این سامانه دارای آسیب‌پذیری Http Smuggling می‌باشد.

نکته: ممکن است ادرس در تصویر به صورت اشتباه بنظر برسد اما صحیح می‌باشد.





راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری، پیشنهاد می‌گردد تا موارد زیر مورد توجه قرار گیرد:

- **استفاده از سرورهای همسان:** اطمینان حاصل کنید که تمام سرورها و پروکسی‌های درگیر در زنجیره درخواست، نسخه‌ها و تنظیمات مشابهی دارند تا از تفسیرهای متفاوت جلوگیری شود.
- **فیلتر کردن ورودی‌ها:** ورودی‌هایی که توسط کاربر ارائه می‌شوند باید به دقت فیلتر شوند تا از تزریق رشته‌های نامتعارف جلوگیری شود.
- **تایید و تصدیق طول محتوا:** در درخواست‌های HTTP از هدرهای Content-Length و Transfer-Encoding استفاده می‌شود. اطمینان حاصل کنید که این هدرها با هم سازگار هستند و طول محتوا درست تفسیر می‌شود.
- **بروزرسانی سرورها و پروکسی‌ها:** بسیاری از آسیب‌پذیری‌های HTTP Smuggling به دلیل وجود باگ در سرورها یا پروکسی‌ها است. بروزرسانی مداوم نرم‌افزارها و اعمال پچ‌های امنیتی ضروری است.
- **استفاده از فایروال وب (WAF):** برخی از فایروال‌های وب به صورت خاص برای شناسایی و مقابله با حملات HTTP Smuggling طراحی شده‌اند. تنظیمات آن‌ها را به گونه‌ای انجام دهید که این نوع از حملات شناسایی و مسدود شوند.

۷-۲- فعال بودن XMLRPC

فایل xmlrpc.php در وردپرس به برنامه‌های خارجی اجازه می‌دهد تا با سایت ارتباط برقرار کنند. به طور خاص، این فایل امکان انجام عملیات‌هایی مانند ایجاد و ویرایش مطالب، آپلود تصاویر و موارد دیگر را از طریق درخواست‌های XML-RPC فراهم می‌کند.

آسیب‌پذیری‌های XML-RPC معمولاً مربوط به مشکلات امنیتی در استفاده از این پروتکل در سیستم‌های مدیریت محتوا (مانند وردپرس) یا سرویس‌های دیگر است که از این فناوری برای ارتباطات بین سیستم‌ها استفاده می‌کنند. این پروتکل به سرورها اجازه می‌دهد از طریق ارسال درخواست‌های XML، داده‌هایی را پردازش یا عملیاتی را اجرا کنند. اما اگر این ویژگی به درستی پیکربندی نشود، ممکن است به یک نقطه ورود برای مهاجمان تبدیل گردد. همچنین فایل xmlrpc.php می‌تواند به نفوذگران جهت حملاتی مثل Brute Force Attack و DDOS کمک کند.

پس از بررسی‌های صورت گرفته مشخص گردید xmlrpc در این سامانه غیر فعال نمی‌باشد.

```
[XMLRPC]
[FOUND] XML-RPC ENABLE
[FOUND] Target have XMLRPC vulnerability https://www.fanava.com/xmlrpc.php
[Exploit] <methodCall><methodName>system.listMethods</methodName><params></params></methodCall>
[Verify] <?xml version="1.0" encoding="UTF-8"?>
<methodResponse>
  <fault>
    <value>
      <struct>
        <member>
          <name>faultCode</name>
          <value><int>-32700</int></value>
        </member>
        <member>
          <name>faultString</name>
          <value><string>parse error. not well formed</string></value>
        </member>
      </struct>
    </value>
  </fault>
</methodResponse>
```

راهکار پیشنهادی:

به منظور رفع این آسیب‌پذیری پیشنهاد می‌شود تا موارد زیر در نظر گرفته شده و در برنامه اعمال گردد:

- غیرفعال کردن XML-RPC در صورتی که به آن نیازی نیست.
- استفاده از افزونه‌های امنیتی در WordPress مانند Wordfence.
- اعتبارسنجی و پاکسازی ورودی‌ها در متدهای XML-RPC.
- نظارت بر لاگ‌های سرور برای شناسایی درخواست‌های مشکوک.

- محدود کردن تعداد درخواست‌هایی که می‌توان در یک بازه زمانی ارسال کرد.

همچنین اطمینان حاصل شود که متدهای XML-RPC نیازمند احراز هویت مناسب بوده و از پروتکل‌هایی مانند OAuth یا توکن‌های یکبار مصرف استفاده می‌کنند.

۸-۲- فعال بودن WP-Cron

فعال بودن ویژگی wp-cron در وردپرس می‌تواند با وجود کاربردهای مفید، چند خطر و مشکل برای عملکرد سایت به همراه داشته باشد. برخی از خطرات فعال بودن این ویژگی در زیر نوشته شده است.

۱. کاهش سرعت سایت

Wp-cron به طور پیش‌فرض با هر بار بازدید از سایت اجرا می‌شود. اگر سایت شما بازدیدکنندگان زیادی داشته باشد، این باعث می‌شود که تعداد زیادی درخواست به wp-cron.php ارسال شده و در نتیجه بار اضافی بر روی سرور ایجاد کند.

این بار اضافی ممکن است موجب کندی سرعت بارگذاری صفحات سایت و تجربه کاربری منفی شود.

۲. مصرف منابع سرور

اجرای مداوم wp-cron ممکن است باعث مصرف منابع سرور، از جمله پردازنده (CPU) و حافظه (RAM) شود.

این مشکل به ویژه در سایت‌هایی با ترافیک بالا یا سرورهایی با منابع محدود برجسته می‌شود، که ممکن است به کاهش کارایی کل سیستم منجر شود.

۳. مشکلات امنیتی

در صورتی که هکرها بتوانند به فایل wp-cron.php دسترسی پیدا کنند یا آن را دستکاری کنند، ممکن است این ویژگی را برای اجرای کدهای مخرب یا حملات مختلف استفاده کنند.

٤. بار اضافی روی پایگاه داده

اجرای مکرر وظایف در wp-cron ممکن است باعث ارسال درخواست‌های زیاد به پایگاه داده شود. این می‌تواند منجر به کاهش سرعت عملکرد پایگاه داده و در نهایت کاهش سرعت کلی سایت شود.

```
[WP-CRON]
[FOUND] WP-CRON ENABLE
[FOUND] Target have WP-CRON vulnerability https://www.fanava.com/wp-cron.php
```

راهکار پیشنهادی:

پیشنهاد می‌شود برای رفع این آسیب‌پذیری و غیرفعال کردن ویژگی wp-cron از روش زیر استفاده شود.

۱. غیرفعال کردن wp-cron از طریق فایل wp-config.php

ابتدا وارد پنل مدیریت‌هاست یا سرور خود شوید، به پوشه اصلی نصب وردپرس بروید (جایی که فایل‌های اصلی وردپرس قرار دارند)، فایل wp-config.php را پیدا کرده و آن را ویرایش کنید، در این فایل، قبل از خط /* That's all, stop editing! Happy blogging */، کد زیر را اضافه کنید:

define('DISABLE_WP_CRON', true);

این کد باعث می‌شود که ویژگی wp-cron غیرفعال شود و وردپرس دیگر به طور خودکار وظایف زمان‌بندی‌شده را با هر بازدید اجرا نکند.

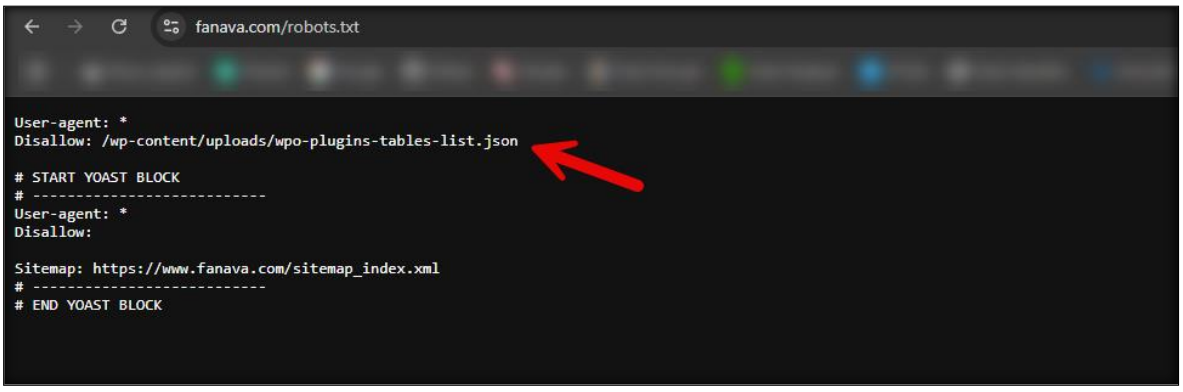
۹-۲- آسیب‌پذیری Information Leakage

یکی از مواردی که در فرآیند تست نفوذ بررسی می‌گردد، امکان افشای اطلاعاتی است که می‌تواند برای نفوذگر مفید بوده و اطلاعات مناسبی را جهت انجام حملات بعدی، در اختیار وی قرار دهد.

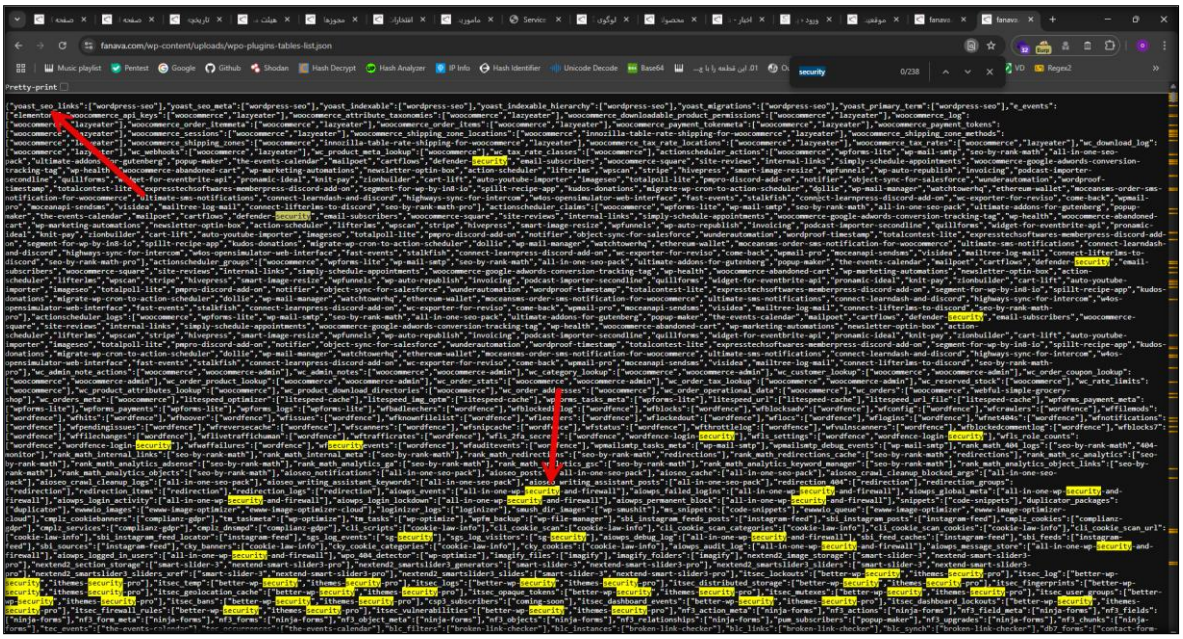
با استفاده از آسیب‌پذیری Directory Browsing به آدرس زیر دست پیدا کرده ایم.

https://www.fanava.com/wp-content/uploads/wpo-plugins-tables-list.json

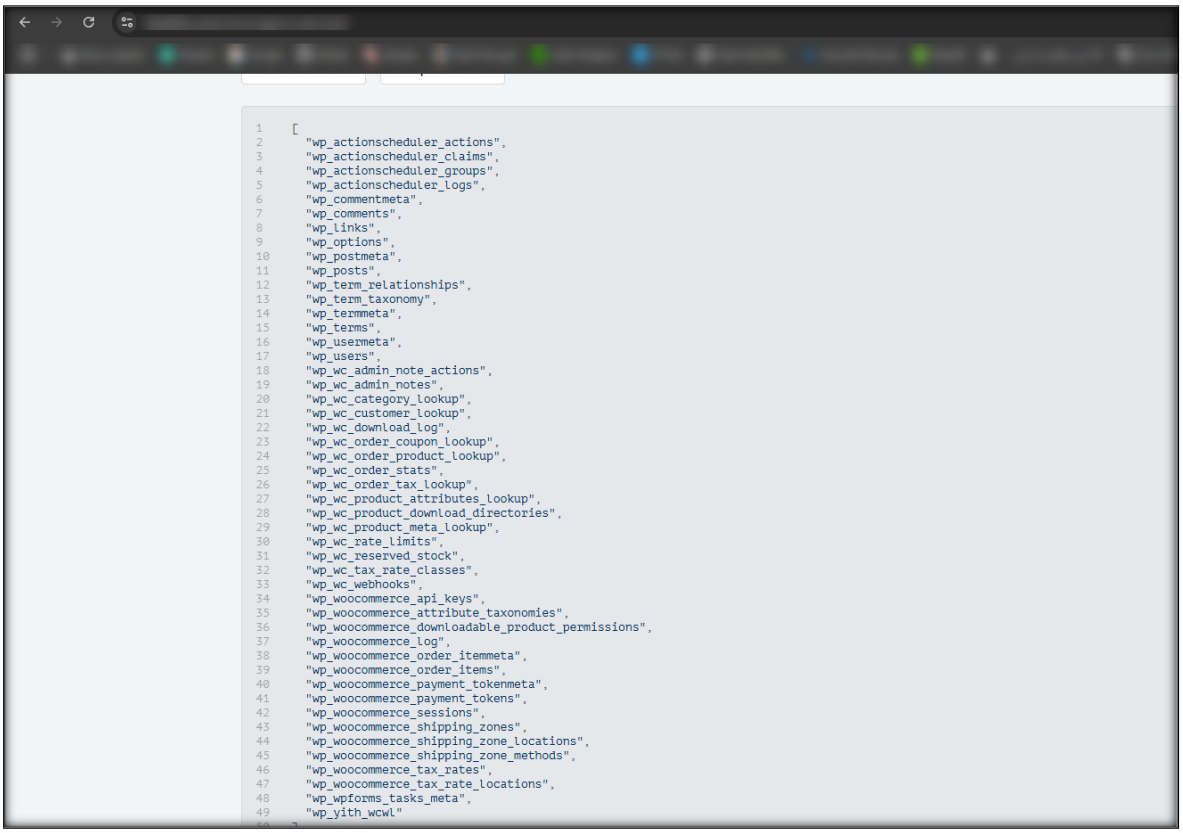
نکته: همچنین این آدرس در مسیر robots.txt/ بصورت کامل نیز ذکر شده است.



در فایل موجود نام افزونه‌های نصب شده در سامانه را می‌توان شناسایی کرد.



همچنین لیستی از جداول پایگاه داده سامانه هدف نیز در این لیست مشاهده می‌شود که به جهت خوانا بودن آن را توسط ابزارهای دیگر استخراج کرده ایم.



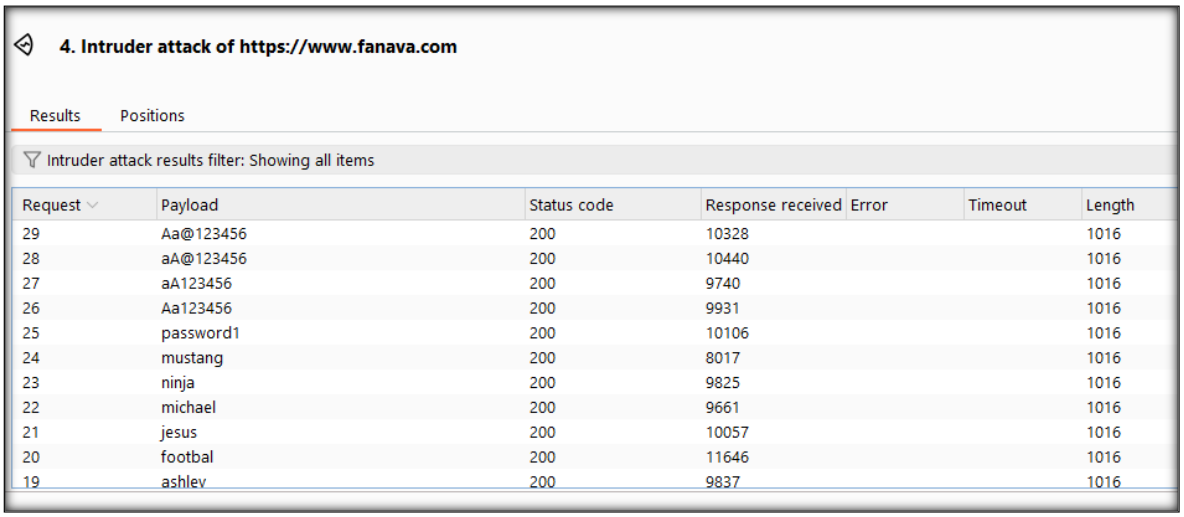
راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری پیشنهاد می‌گردد که نام چنین صفحاتی به گونه‌ای تنظیم شود که قابل حدس و شناسایی نبوده و در صورت امکان به جهت حفظ محرمانگی، این مستندات به صورت محرمانه و خارج از سامانه در اختیار راهبران قرار داده شود.

۱۰-۲- آسیب‌پذیری Weak Lock Out Mechanism

یکی از حملاتی که نفوذگران در اکثر سامانه‌ها به خصوص سامانه‌های وب از آن استفاده می‌کنند، حمله Brute Force می‌باشد. در این حمله نفوذگر با استفاده لیست کلمات عبور پرکاربردی که در اختیار دارد، اقدام به تست آن‌ها به عنوان کلمات عبور سامانه می‌کند. در صورت موفقیت آمیز بودن این حمله، نفوذگر می‌تواند به سامانه وارد شود. به همین منظور باید مکانیزم‌های جلوگیری از چنین حملاتی در سامانه قرار داده شود. علاوه بر استفاده از عبارت CAPTCHA می‌بایست ساختاری برای مسدود سازی حساب‌هایی که تلاش‌های ناموفق برای ورود به سامانه دارند نیز در نظر گرفته شود.

طی بررسی‌های بیشتر مشخص گردید سامانه هدف به علت خطا در Google ReCaptcha هیچ گونه مکانیزم امنیتی جهت جلوگیری از درخواست پی در پی از یک مبدا را نداشته و در برابر حملات BruteForce آسیب‌پذیر می‌باشد


4. Intruder attack of https://www.fanava.com

Results Positions

Intruder attack results filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length
29	Aa@123456	200	10328			1016
28	aA@123456	200	10440			1016
27	aA123456	200	9740			1016
26	Aa123456	200	9931			1016
25	password1	200	10106			1016
24	mustang	200	8017			1016
23	ninja	200	9825			1016
22	michael	200	9661			1016
21	jesus	200	10057			1016
20	footbal	200	11646			1016
19	ashley	200	9837			1016

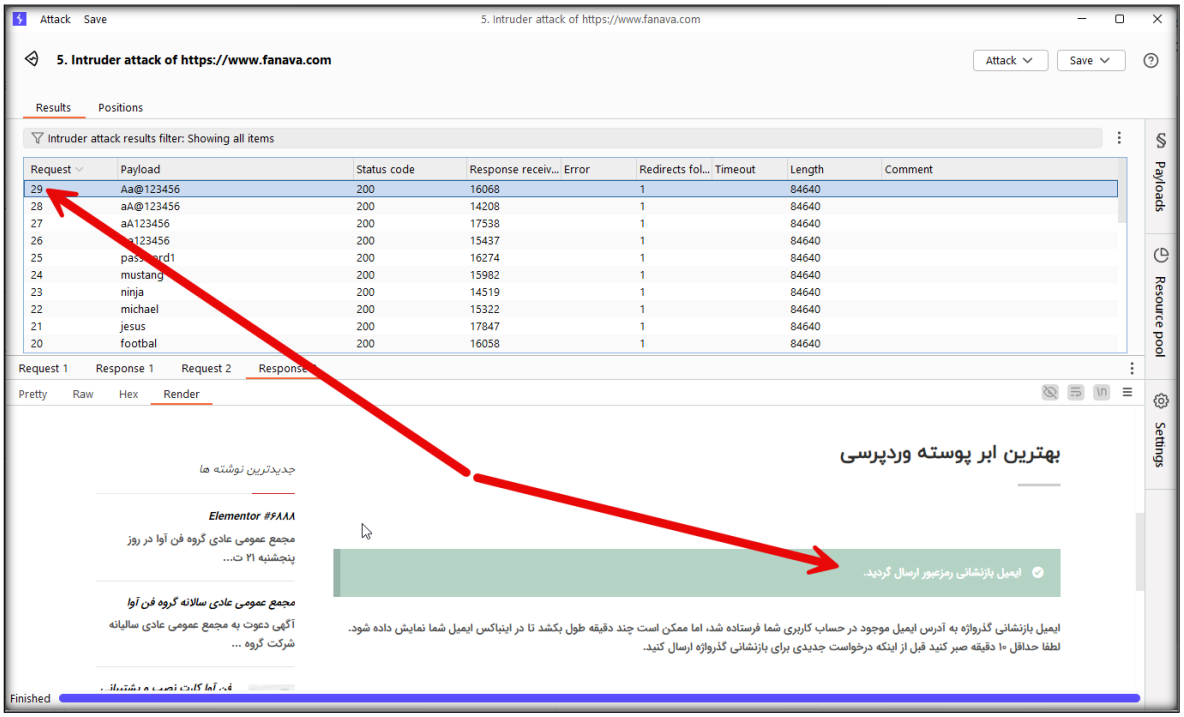
راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری، پیشنهاد می‌گردد تا فرآیندی به منظور مسدودسازی حساب کاربری با تعداد تلاش ناموفق مشخص (۱۰ تلاش ناموفق) ایجاد گردد. همچنین مقدار CAPTCHA استفاده شده در سامانه سمت سرور نیز بررسی شده و با هر بار ارسال درخواست، مقدار آن تغییر پیدا کند.

۱۱-۲- آسیب‌پذیری Rate Limit

حد مجاز به حداکثر تعداد دفعاتی که یک کاربر یا سیستم می‌تواند یک عمل خاص را در یک دوره زمانی مشخص انجام دهد، rate limit گفته می‌شود. این یک مکانیزم رایج برای کنترل حجم ترافیک به یک سرویس وب یا API است تا از بارگذاری بیش از حد سیستم جلوگیری کند و استفاده منصفانه را تضمین نماید. به عنوان مثال، ممکن است یک وب‌سایت به شما اجازه دهد تا حداکثر ۱۰۰ درخواست در ساعت به سرور خود ارسال کنید. اگر از این حد مجاز فراتر بروید، ممکن است موقتا تا زمانی که حد مجاز بازنشانی مسدود گردد و پیام خطا دریافت کند.

حد مجاز برای حفظ پایداری و عملکرد خدمات آنلاین ضروری است. این مکانیزم کمک می‌کند تا از سوءاستفاده‌هایی مانند اسپمینگ یا فعالیت‌های مخرب جلوگیری شود و منابع برای همه کاربران در دسترس باشد.



راهکار پیشنهادی

برای رفع آسیب‌پذیری پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

- محدود کردن تعداد درخواست‌ها وکاهش تعداد درخواست‌ها به سرور یا API با بهینه‌سازی کد و تجمیع درخواست‌ها.
- استفاده از CAPTCHA

- کنترل زمان‌بندی درخواست‌ها و تنظیم زمان‌بندی درخواست‌ها به‌طوری‌که در زمان کوتاه تعداد زیادی درخواست ارسال نشود.

۱۲-۲- آسیب‌پذیری Nginx Version Disclosure

در مرحله جمع آوری اطلاعات، در صورت شناسایی نسخه مربوط به سرور وب و همچنین زبان برنامه نویسی سامانه، این امکان وجود دارد که با بررسی آسیب‌پذیری‌های موجود در نسخه جاری وب سرور و برنامه تحت وب، آسیب‌پذیری‌های مربوط به آن شناسایی شده و در جهت وارد نمودن آسیب به برنامه از آن‌ها بهره برداری شود. به همین دلیل، مخفی نمودن نسخه سرور وب و برنامه تحت وب، روشی به منظور پیشگیری از خطرات مذکور را فراهم می‌کند.

نسخه مربوط به سرور وب Nginx در سامانه، قابل مشاهده می‌باشد:

```
[HEADERS]
[FOUND] Server : nginx/1.12.2
[FAILD] X-Powered-By
[FAILD] X-AspNet-Version
[FAILD] X-AspNetMvc-Version

[SECURITY HEADERS]
[FAILD] X-Frame-Options
[FAILD] X-XSS-Protection
[FAILD] Cache-Control
[FAILD] X-Content-Type-Options
[FAILD] Strict-Transport-Security
[FAILD] Content-Security-Policy
```

راهکار پیشنهادی

پیشنهاد می‌شود جهت رفع این آسیب‌پذیری، در فایل پیکربندی وب سرور (nginx.conf) مقدار زیر را در قسمت Basic Setting اضافه نموده و وب سرور را ریستارت نمایید:

server_tokens off;

۱۳-۲- آسیب‌پذیری Information Disclosure

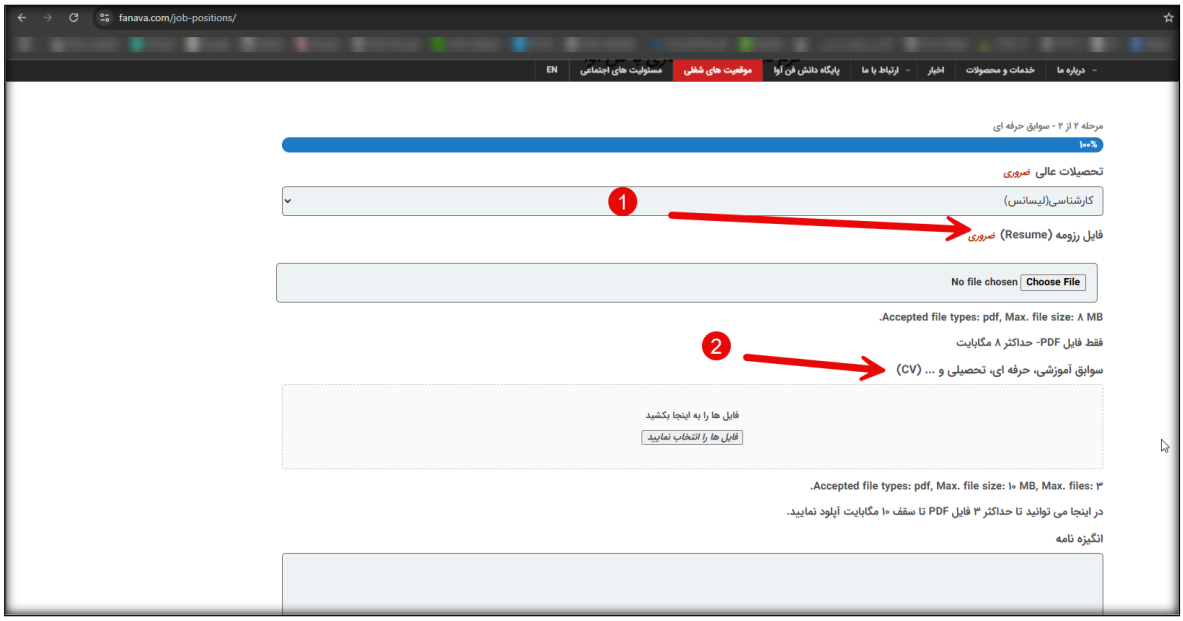
آسیب‌پذیری Information Disclosure یا افشای اطلاعات به حالتی گفته می‌شود که در آن یک سیستم به طور غیرمجاز اطلاعاتی را که نباید فاش شود، به فردی که مجاز به دسترسی به آن نیست، نشان می‌دهد. این اطلاعات می‌تواند شامل جزئیات حساس مانند پیکربندی سرور، مسیرهای فایل، پیغام‌های خطا، یا اطلاعات مرتبط با سیستم باشد که می‌تواند برای حمله‌کنندگان مفید واقع شود.

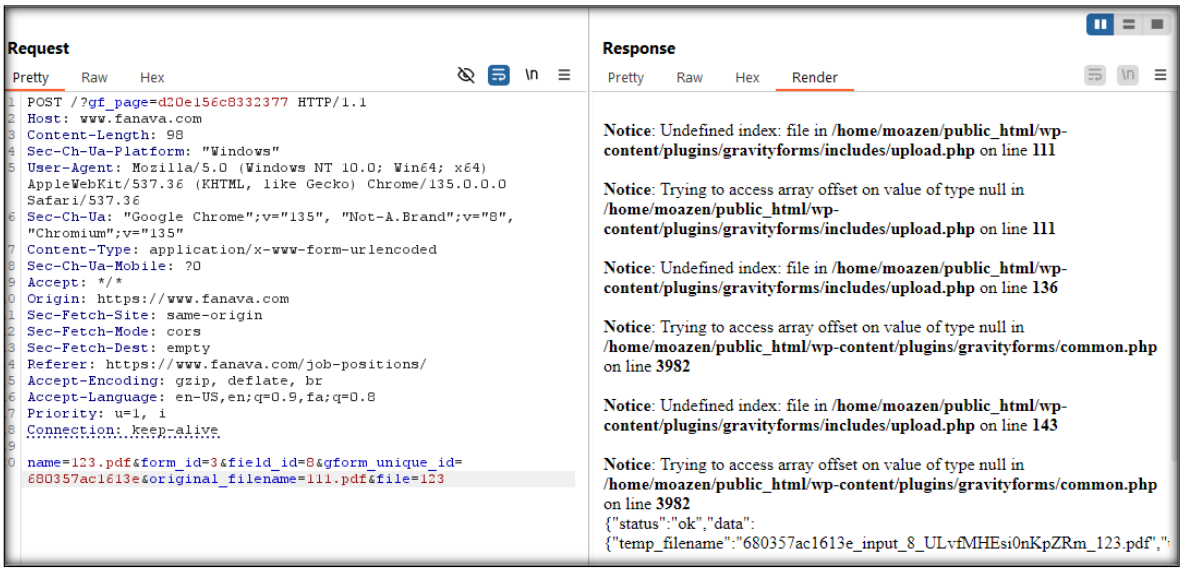
پس از بررسی‌های صورت گرفته مشخص گردید سامانه هدف در زمان بارگزاری فایل pdf در بخش همکاری با ما به لینک زیر دارای خطا بوده که این خطا مسیر داخلی سایت را نشت میدهد

https://www.fanava.com/job-positions/

نکته: در صفحه موقعیت‌های شغلی ۲ بخش برای بارگذاری فایل وجود دارد، که فقط در بخش بارگذاری فایل دوم درخواست بصورت خودکار به مسیر زیر ارسال می‌گردد.

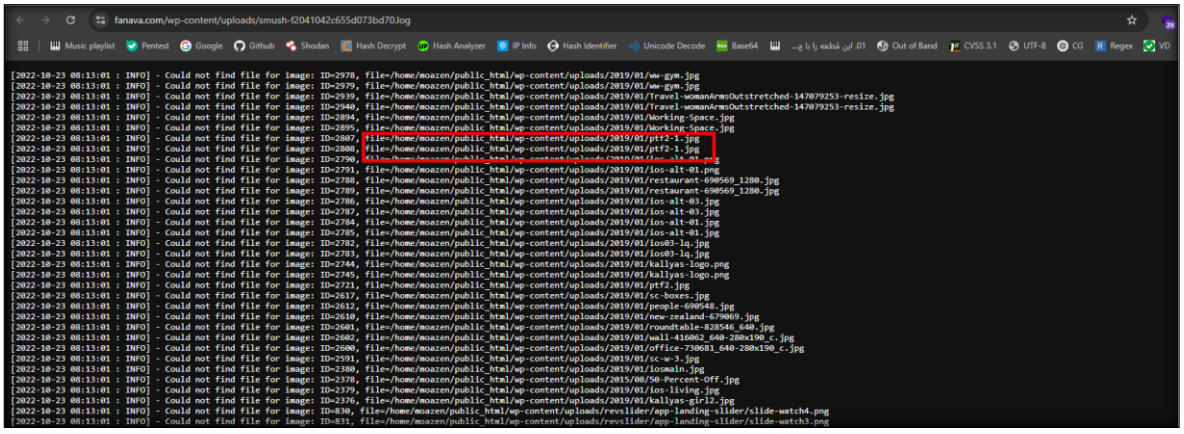
https://www.fanava.com/?gf_page=d20e156c8332377





همچنین به وسیله آسیب‌پذیری Directory Browsing فایل log به ادرس زیر کشف گردید که در این فایل نیز مسیر داخلی سامانه هدف وجود دارد.

https://www.fanava.com/wp-content/uploads/smush-f2041042c655d073bd70.log



راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

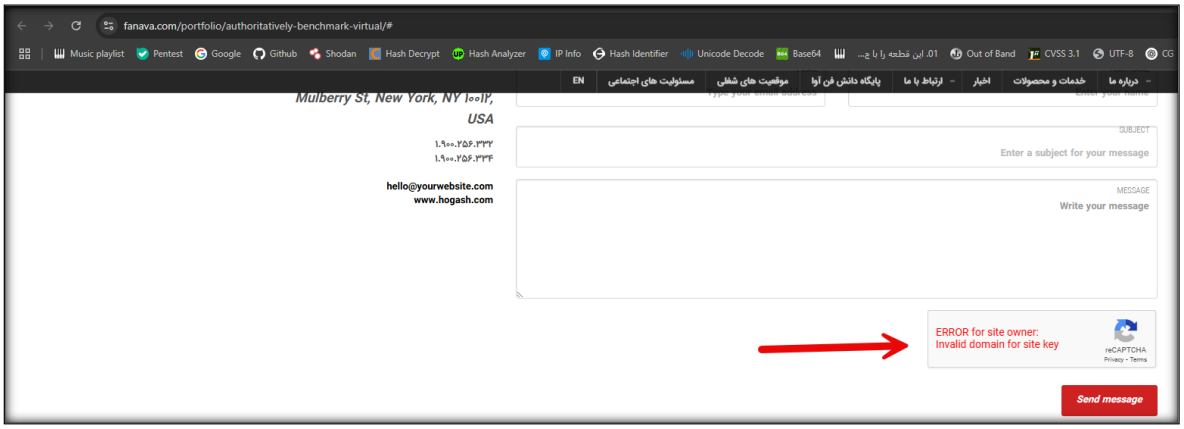
- **پیکربندی مناسب سرور:** پیغام‌های خطا و جزئیات پیکربندی سرور باید محدود یا غیرفعال شوند.
- **کنترل دسترسی مناسب:** از دسترسی‌های مناسب برای کاربران و مدیران سیستم استفاده کنید و از دسترسی غیرمجاز به اطلاعات حساس جلوگیری کنید.

- **استفاده از ابزارهای امنیتی:** از ابزارهایی مانند فایروال‌ها و پلاگین‌های امنیتی برای محدود کردن افشای اطلاعات و مدیریت ترافیک ورودی استفاده کنید.

اطلاعات

طی بررسی‌های صورت گرفته مشخص گردید سامانه هدف ناپایدار بوده و در بعضی از بخش‌ها دارای خطا می‌باشد،





همچنین صفحات پیش‌فرض غیر قابل استفاده نیز حذف نشده اند.

